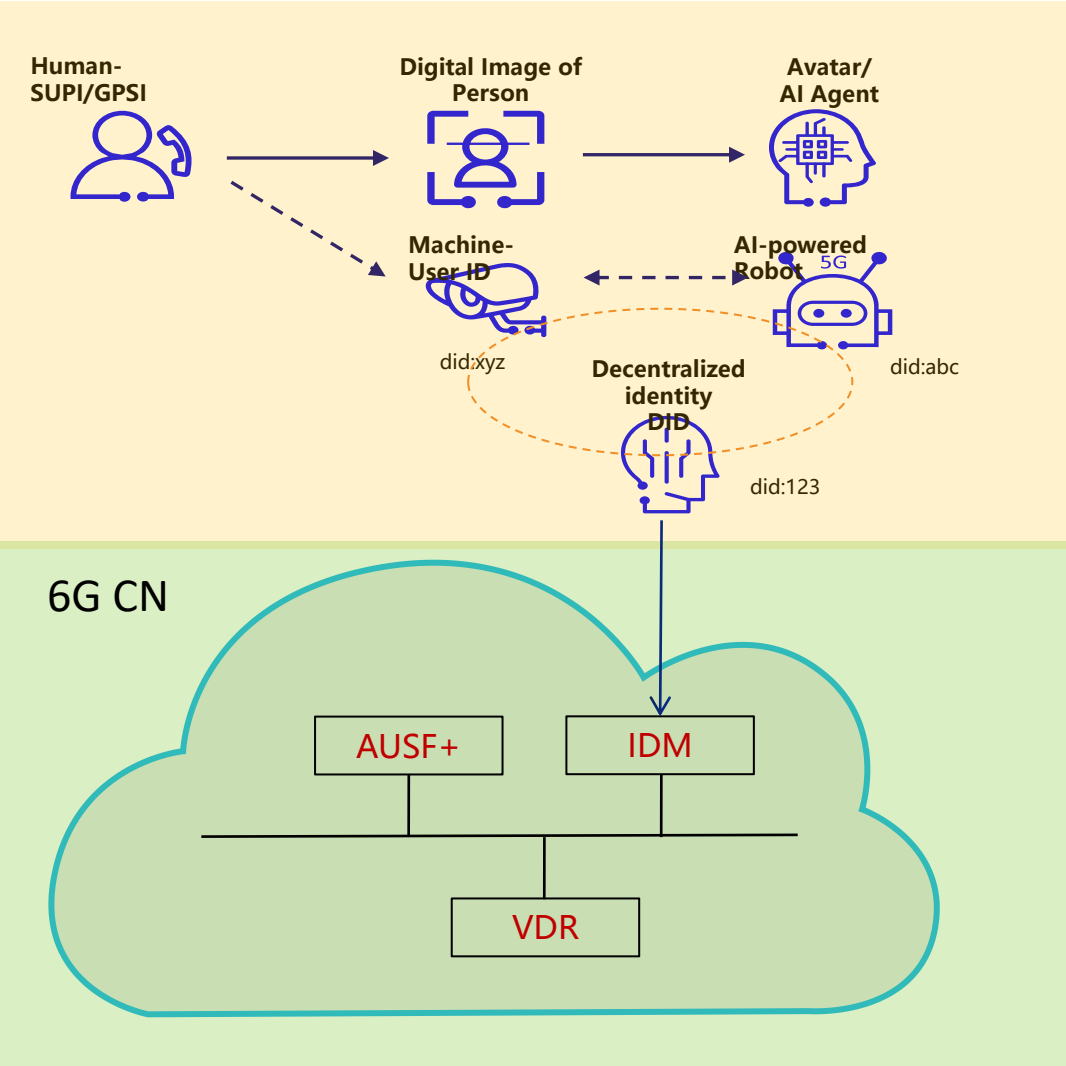
AI Agent Authentication and Authorization New Requirements

Meiling Chen(China Mobile)

Email:chenmeiling@chinamobile.com

UE AI agent authentication and authorization(ACN)



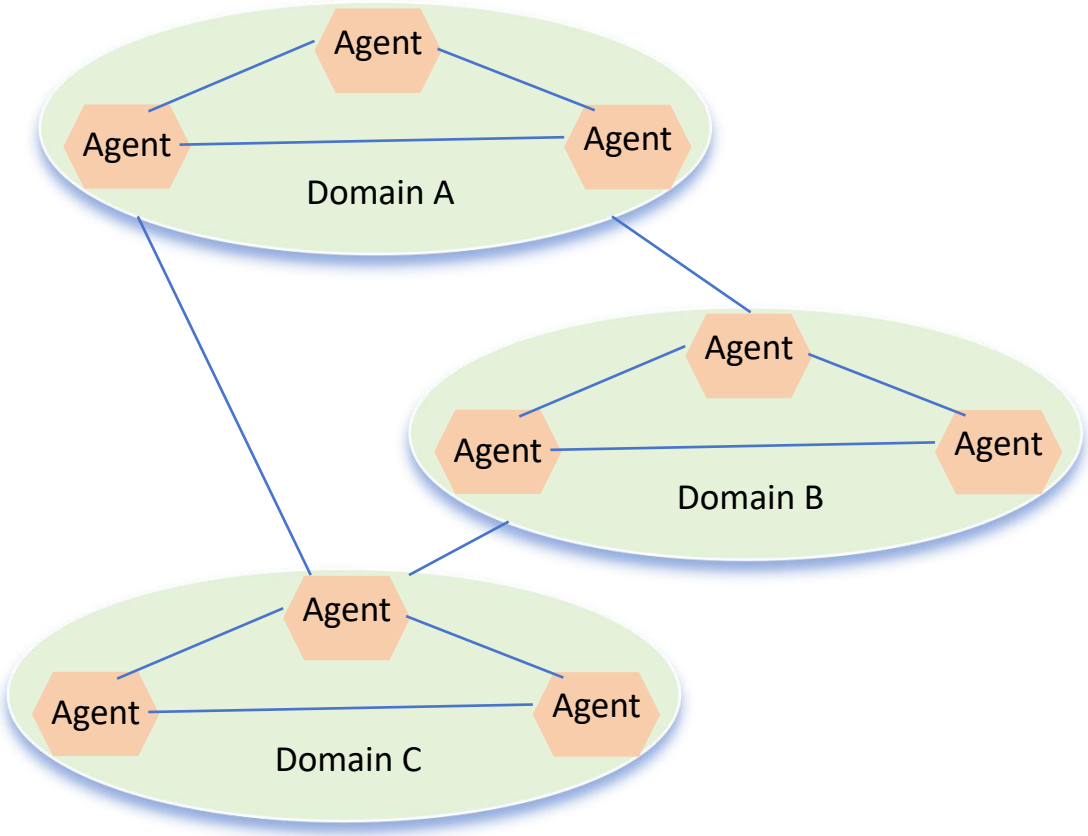
- Traditional authentication mechanisms based on SUPI cannot meet the decentralized, cross-domain, and dynamic access requirements of AI Agents.

➢ Requirements on AI agent authentication and authorization

Authentication :
- The 6G network shall support mutual authentication between UE AI Agents and the network, as well as among multiple AI Agents.
- Support delegated authentication, where an AI Agent can authenticate on behalf of its human user (with appropriate proof of delegation).
- Support continuous or re-authentication during session mobility or when the Agent's behavior context changes significantly.
- Authentication protocols shall be agnostic to multiple identity formats (e.g., SUPI/GPSI and DIDs).

Authorization:
- Support fine-grained authorization based on identity, role, capabilities, and the human user's consent.
- Authorization policies shall be dynamic and context-aware, enabling real-time permission adjustment.
- Support capability-based authorization to grant specific permissions for invoking network functions.
- Enable authorization delegation, allowing AI Agents to temporarily grant permissions to other Agents under controlled conditions.

AI agent authentication and authorization (IoA)



New Authentication Requirements
From "Who are you?" ➜ "Are you still trustworthy?"

1. Traceable Identity & Provenance
- What: Log an agent's origin (genesis) and its entire, cryptographically signed call chain.
- Why: To answer "Where did it come from?" for clear accountability.

2. Continuous Behavioral Attestation
- What: Require agents to periodically report a "heartbeat" of their recent actions.
- Why: To detect hijacking or malicious drift in real-time, even if its credential is valid.

3. Ultra-Low-Overhead Management
- What: Enable near-zero cost for creating and verifying identities.
- Why: To support massive scales of ephemeral agents that may exist only for milliseconds.

New Authorization Requirements
From "What can you do?" ➜ "What are you allowed to do, right now?"

1. Just-in-Time (JIT) & Intent-Driven Permissions
- What: Grant minimal, precise permissions only for the exact moment a task is executed.
- Why: To enforce least privilege and ensure permissions expire immediately after use.

2. Rich Context & Risk-Awareness
- What: Decisions must consider rich context: the agent's intent, operational risk, behavioral patterns, etc.
- Why: To make authorization smarter and dynamically adapt to the current situation.

3. Explainable & Auditable Authorization
- What: Responses must include not just "Allow/Deny," but also the rationale (the 'why').
- Why: To answer "Why was this action authorized?" for post-mortem audits.

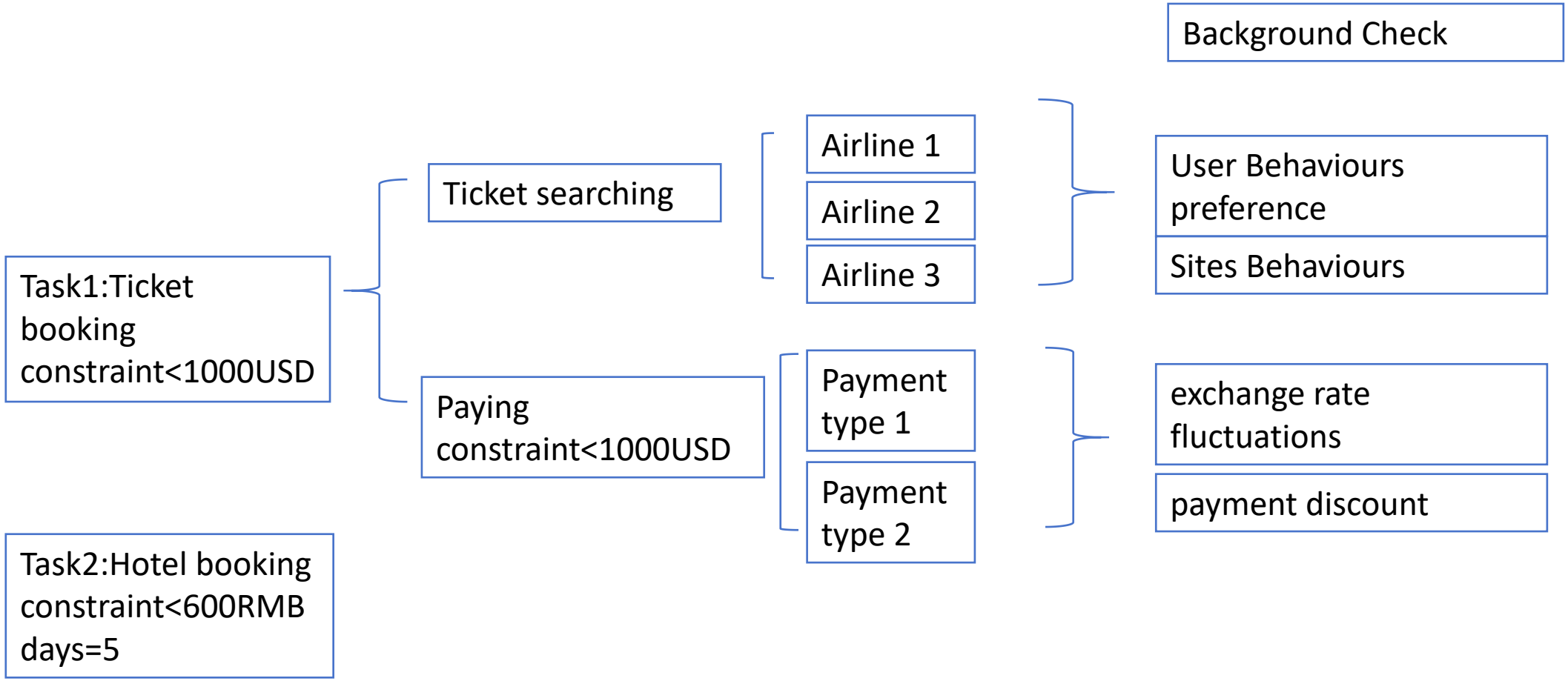
Common authorization requirements

1. Fine-grained	2. Audit	3. Dynamic
Principle: Intent-Based Least Privilege "Know what it wants to do, before it does it."	Principle: Behavior-Based Continuous Verification "Ensure it stays in bounds, while it's acting."	Principle: Just-in-Time (JIT) Lifecycle Control "Permissions exist only for the exact moment they are needed."
How it Works: **Intent Decomposition**: Break down high-level user goals (e.g., "Book me a flight to Shanghai") into discrete, actionable sub-tasks. **Permission Scoping:** Generate minimal, precise permission constraints tailored to each specific sub-task before execution.	How it Works: **Stateful Auditing**: Continuously monitor the agent's real-time state and actions, validating them against its granted policies. **External Policy Checks**: Integrate with external security engines (e.g., risk or fraud detection systems) to provide secondary validation for sensitive operations.	How it Works: **JIT Acquisition:** The agent requests and is granted specific permissions only at the moment a task is initiated. **Instant Revocation:** Permissions are automatically revoked the instant a task is completed, fails, or times out, ensuring a "zero-standing-privileges" state.

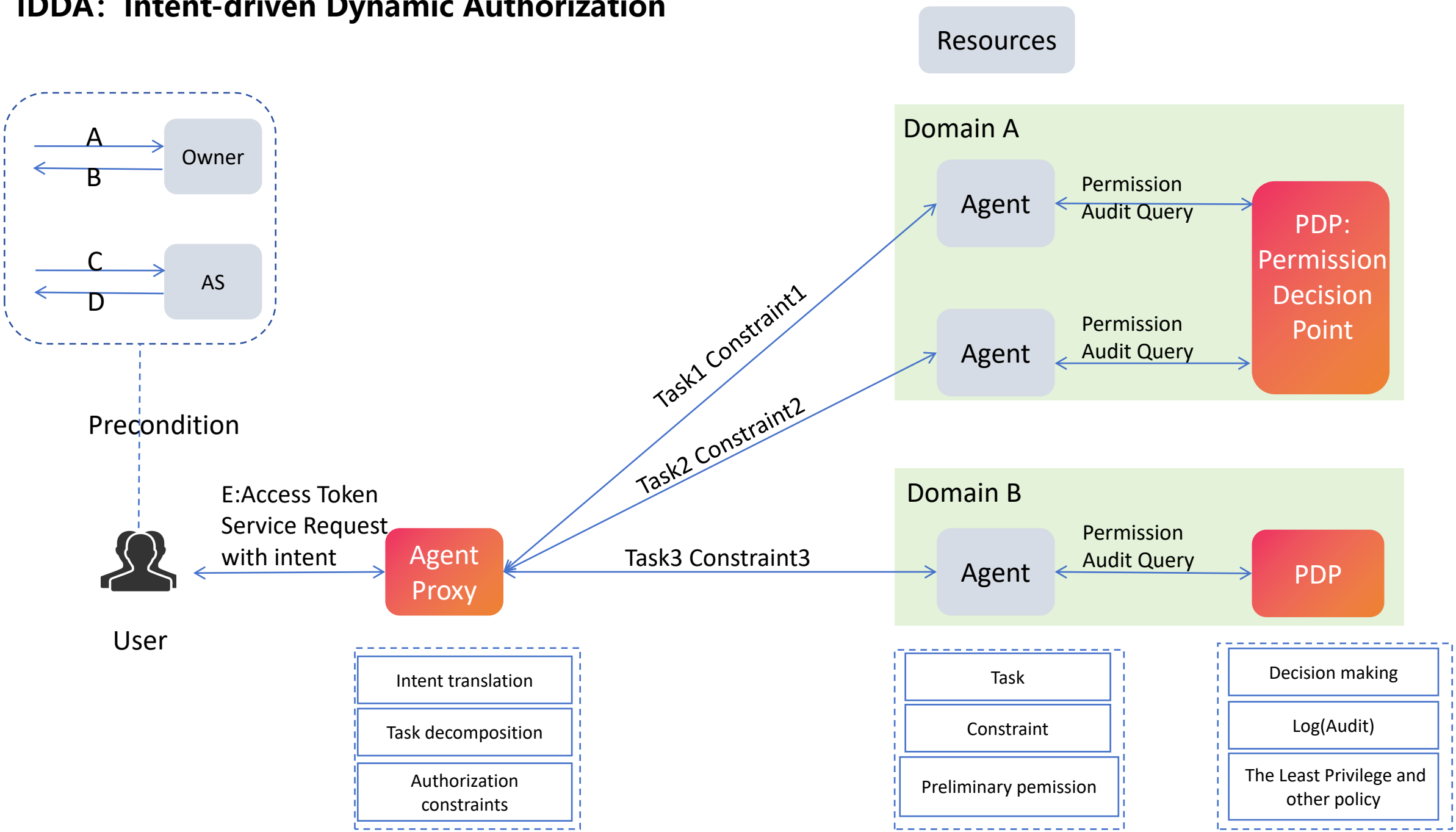
Fine-grained defines what's allowed, Audit verifies what's happening, and Dynamic ensures permissions only exist when needed

Use Case

- Bob:”Hi, Alice, please help me book a flight ticket for March 15th in the afternoon, flying from London to Shenzhen. The cost should not exceed 1000 US dollars. and book hotel”



IDDA：Intent-driven Dynamic Authorization



Our Drafts

- draft-chen-ai-agent-auth-new-requirements-00 - New requirements for Authentication and Authorization in the AI Agents era
- draft-chen-agent-decoupled-authorization-model-00 - A Decoupled Authorization Model for Agent2Agent
- draft-chen-oauth-scope-agent-extensions-00 - Structured and Constraint Extensions for OAuth Scopes
- draft-chen-oauth-rar-agent-extensions-00 - Policy and Lifecycle Extensions for OAuth Rich Authorization Requests